

Ni l'enseignant ni l'institut ne sont responsables de la mauvaise utilisation du contenu de ce cours. L'utilisation des outils doit être réalisée uniquement dans un environnement virtuel ou avec un accord écrit de l'entreprise.

Mise en place d'une attaque DHCP spoofing

Objectifs : à la fin de ce cours, l'étudiant doit être capable de :

- Expliquer et réaliser une attaque DHCP spoofing pour mettre en place un DoS
- Expliquer et réaliser une attaque DHCP spoofing pour effectuer un MITM
- Etudier et proposer une solution contre les différentes attaques ci-dessus.

Contexte de TP :

Dans cette partie, on verra d'une part comment un hacker procède pour mettre en place une attaque de type DoS contre le service DHCP d'un organisme et pousser les hôtes du réseau cible à recevoir les adresses délivrées par son faux serveur DHCP.

D'autre part, vous allez empoisonner les entrées DNS d'une machine cible.

1.Mise en place d'une attaque DoS à l'aide des paquets DHCP discover

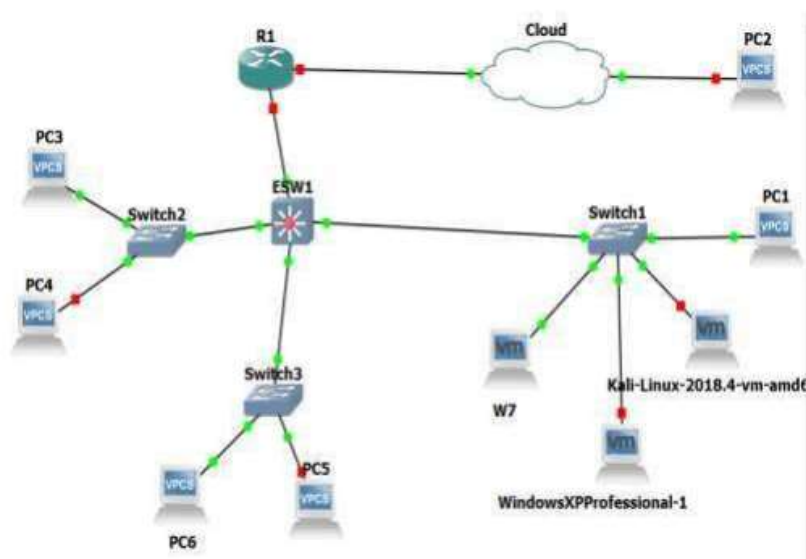
Quand nous voulons effectuer un test d'intrusion dans un réseau, nous devons connaître le rôle de tous les ordinateurs connectés à ce réseau.

Utilisez l'outil nmap, pour scanner le réseau et construire le réseau que vous devez effectuer votre test d'intrusion. L'objectif ici est de se mettre dans la peau d'un vrai hacker qui doit avant toute action collecter les informations concernant le réseau cible.

Liste des besoins :

1. Une machine Kali Linux, avec deux interfaces (Host Only et NAT) pour effectuer les différentes attaques
2. Un commutateur Cisco et un routeur Cisco qui nous servira de serveur DHCP
3. Une machine W10 qui sera la victime
4. Des VPCS

Avant tout, dans **GNS3**, configurez le service DHCP sur le routeur et mettez les machines en DHCP. Vous devez vous rassurer que toutes les machines communiquent entre elles.



Préparation de l'attaque

A l'aide de votre machine Kali Linux, vous allez utiliser l'outil **yersinia** pour lancer une attaque DoS sur le service DHCP.

Yersinia est un outil réseau conçu pour tirer parti de certaines faiblesses dans différents protocoles réseau. Il prétend être un cadre solide pour analyser et tester les réseaux et les systèmes déployés.

Il se compose de diverses attaques de couche 2 exploitant les faiblesses de différents protocoles de couche 2. Ainsi, un pentester peut identifier les vulnérabilités dans la couche profonde 2 du réseau. Pendant les pentests, yersinia est utilisé pour lancer des attaques sur des périphériques de couche 2 tels que des commutateurs, des serveurs dhcp couvrant des protocoles d'arborescence, etc. Actuellement, yersinia prend en charge :

- Protocole STP (Spanning Tree Protocol)
- Protocole de découverte Cisco (CDP)
- Protocole DTP (Dynamic Trunking Protocol)
- Protocole DHCP (Dynamic Host Configuration Protocol)
- Protocole HSRP (Hot Standby Router Protocol)
- NORME IEEE 802.1Q
- NORME IEEE 802.1X
- Protocole ISL (Inter-Switch Link Protocol)
- Protocole VTP (VLAN Trunking Protocol)

Les options de yersinia sont les suivantes :

```

Usage: yersinia [-hVGIDD] [-l logfile] [-c conffile] protocol [protocol_options]
  -V Program version.
  -h This help screen.
  -G Graphical mode (GTK).
  -I Interactive mode (ncurses).
  -D Daemon mode.
  -d Debug.
  -l logfile Select logfile.
  -c conffile Select config file.
  protocol One of the following: cdp, dhcp, dot1q, dot1x, dtp, hsrp, isl, mpls, stp, vtp.
Try 'yersinia protocol -h' to see protocol_options help

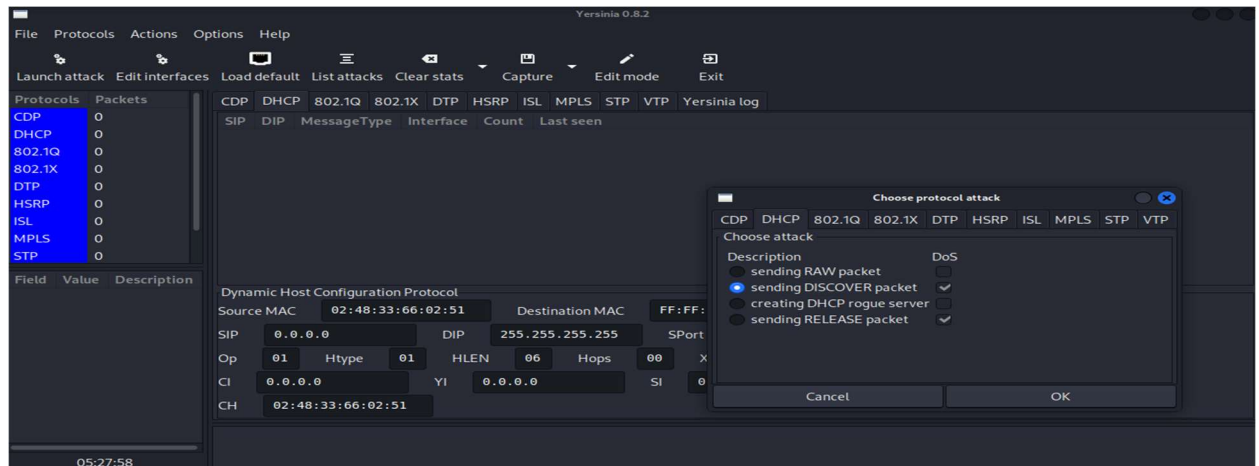
```

Pour lancer yersinia en mode graphique, tapez :

yersinia -G pour l'interface graphique

Pour effectuer un DoS sur le serveur DHCP légitime, vous devez suivre les étapes suivantes :

Launch attack > DHCP > sending DISCOVER packet et validez sur **ok**



A l'aide de Wireshark, analysez le trafic sur l'interface de connexion de votre machine Kali Linux.

Que constatez-vous ?

Essayez de récupérer une adresse avec votre machine victime W10.

Que constatez-vous ?

2. Simulation d'une attaque de type MITM

A l'aide de vos précédentes configurations, le serveur DHCP ne répond plus aux requêtes des différents utilisateurs. Maintenant, vous devez configurer votre faux serveur DHCP.

Appelé en français « attaque de l'homme du milieu », une attaque *man-in-the-middle* est une cyberattaque s'immisçant entre 2 entités communicantes de manière à intercepter ou altérer les communications et voler des données. Un pirate informatique utilisera une attaque man-in-the-middle (ou MITM) dans le but de récupérer des données. Il peut ensuite les utiliser, les altérer ou les supprimer. Dans le cas d'une attaque basée sur DHCP, l'ordinateur propre du hacker (ou celui qui est sous son contrôle) au sein d'un réseau local (LAN) est présenté en tant que serveur DHCP. Un serveur DHCP est un élément important dans le réseau local, il est en effet responsable de l'attribution de la configuration réseau à d'autres ordinateurs du LAN. Ceci est normalement réalisé automatiquement : dès qu'un ordinateur se connecte au LAN, le client DHCP du système d'exploitation réclame des informations comme l'adresse IP locale, le masque de réseau, l'adresse passerelle par défaut ainsi que l'adresse de serveur DNS approprié. Pour ce faire, il

envoie un message de diffusion générale à tous les appareils dans le LAN et attend la confirmation d'un serveur DHCP. La première réponse détaillée est alors acceptée. Ceci permet aux hackers par l'intermédiaire d'un serveur DHCP factice de contrôler l'allocation des adresses IP locales, d'entrer n'importe quelle passerelle par défaut et serveur DNS sur les ordinateurs trompés et ainsi de détourner le trafic sortant vers n'importe quel autre ordinateur pour intercepter ou manipuler le contenu.

Comme ce modèle d'attaque est basé sur la manipulation du système DHCP, il est nommé DHCP Spoofing (pour « usurpation » en français).

Pour mettre en place, votre faux serveur DHCP, vous devez configurer une interface réseau (host only) depuis VMWare workstation avec les mêmes caractéristiques que la première carte réseau

Installez le package « isc-dhcp-server » :

- Dans le fichier « /etc/default/isc-dhcp-server » ajouter la première interface Host-Only
- Ensuite ajoutez votre range dans le fichier « /etc/dhcp/dhcpd.conf ». Les paramètres à prendre en compte :
 - o La passerelle est l'adresse ip de la deuxième interface Host-Only
 - o Range différent de celui utilisé dans le routeur
 - o Domaine « Cyber.lab »
 - o DNS « 1.1.1.1 »

Activez le routage de tous les paquets vers votre machine kali :

echo 1 > /proc/sys/net/ipv4/ip_forward

Activez la fonctionnalité de translation d'adresse :

iptables -t nat -A POSTROUTING -o ethX -j MASQUERADE (ethX est l'interface NAT utilisé par la machine KALI)

Avant de lancer le service « isc-dhcp-server » refaites la manipulation avec « yersinia » pour être sûr que le routeur a réservé toutes sa plage d'adressage.

Avant d'exécuter votre attaque, faites un tracert entre votre poste victime W10 et le VPCS PC2.

Que constatez-vous ?

Arrêter l'attaque de DoS faites avec yersinia avec la commande : **yersinia -I**.

Vous pouvez démarrer votre faux serveur avec la commande : « systemctl start isc-dhcp-server »

Sur votre machine W10 essayez de récupérer une nouvelle adresse.

Que constatez-vous ?

Faites un tracert entre le poste W10 et le VPCS PC2 :

Que constatez-vous ?

Les attaques basées sur le protocole DHCP reposent sur l'épuisement de ces ressources. Ainsi pour éviter une telle attaque, nous devons surveiller notre DHCP.

Deux mécanismes à prendre en compte

Configuration des port-security

Sur les ports des switchs qui connectent les hôtes ajoutez les commandes « port-security » en mode sticky et en acceptant que 2 MAC addresses

Configuration de la surveillance DHCP (DHCP Snooping)

vous devez activer la surveillance DHCP avec la commande suivante :

```
sw1(config)#ip dhcp snooping
sw1(config)#ip dhcp snooping vlan 1
sw1(config)#
*Apr 17 22:48:42.194: %DHCP_SNOOPING-5-DHCP_SNOOPING_UNTRUSTED_PORT
rusted port, message type: DHCP OFFER, MAC sa: ca01.1454.0000
```

Le message LOG que vous avez reçu indique que, tous les paquets de type DHCP OFFER sont bloqués.

Vous devez par conséquent indiquer que le serveur DHCP de confiance est celui relié à l'interface **fa0/0** de notre switch.

```
sw1(config)#int e0/0
sw1(config-if)#ip dhcp snooping trust
```

Puis nous désactivons l'option 82 qui correspond à l'option agent DHCP relais.

```
#no ip dhcp snooping information option
```

Et enfin, nous devons limiter le nombre de paquet **DHCP DISCOVER** envoyé par un client DHCP.

```
sw1(config)#int range e0/2-3
sw1(config-if-range)#ip dhcp snooping limit rate 3
```

Sauvegardez votre configuration et arrêtez le serveur DHCP de Kali.

Relancez Yersinia, faites une demande nouvelle demande DHCP depuis votre WIN10.

A vous de jouer !!!!